

NIS2 Compliance Assessment Report

Organization: Specialized Diagnostic Clinic (Small)

Date: 2026-06-15

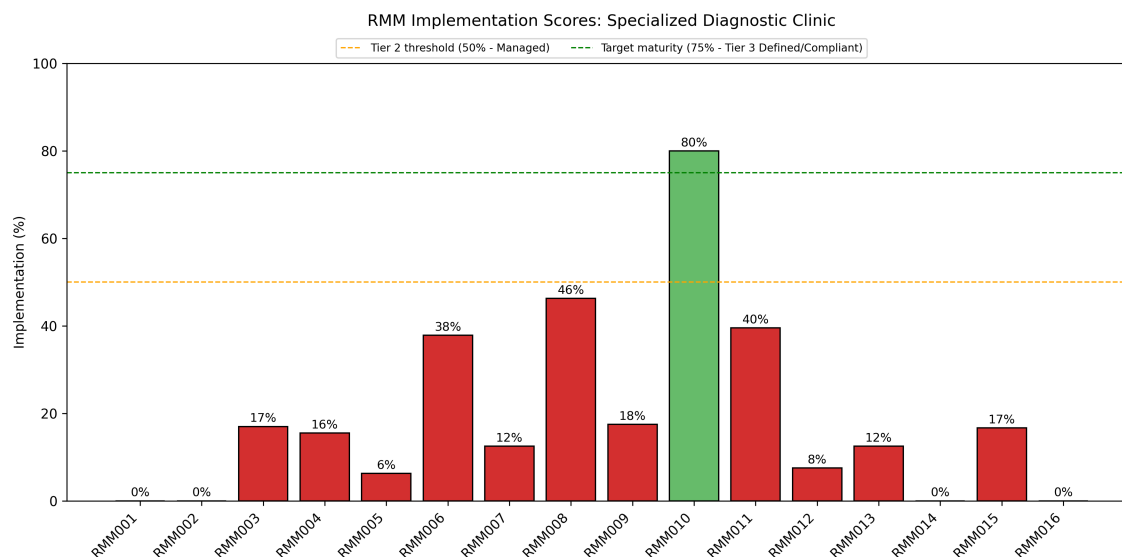
Data source: Small specialized clinic with heavy MSP outsourcing (constructed from public NCSC/HSE/ENISA benchmarks)

Overall Score	17.9%
Maturity Tier	Tier 1 - Initial (Non-Compliant)
Target Maturity	75% (Tier 3 - Defined/Compliant)

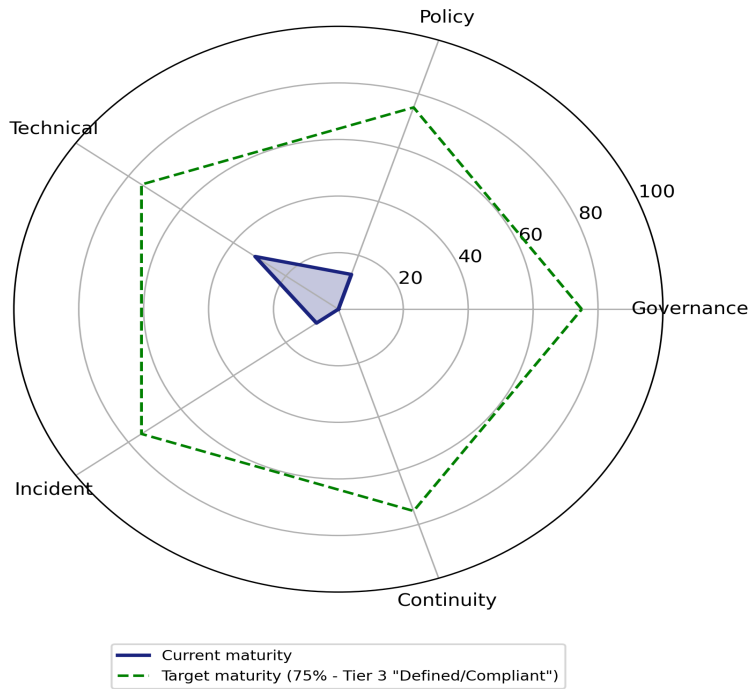
How to read this score. Each question is answered Yes (4 pts), Partial (1 pt) or No (0 pts) and multiplied by a weight (critical controls such as MFA and 24h reporting carry higher weight, so RMM scores are *not* weighted equally). Each answer is further scaled by an evidence-assurance factor (None 0.0 / Low 0.5 / Medium 0.8 / High 1.0), so claims without evidence score lower. The overall percentage is the weighted, assurance-adjusted total divided by the maximum achievable. Maturity tiers: Tier 1 Initial 0-49%, Tier 2 Managed 50-74%, Tier 3 Defined/Compliant 75-89%, Tier 4 Optimized 90-100%. The target for a small healthcare entity is Tier 3 (75%). For this assessment the assurance-adjusted weighted score is 26.5 of a possible 148.0 points = 17.9%, placing the organization in Tier 1.

Executive Risk Statement

As of 2026-06-15, Specialized Diagnostic Clinic scores 17.9% (Tier 1 - Initial (Non-Compliant)) against NIS2 risk-management requirements. The organization is currently non-compliant with NIS2. Critical safeguards for clinical systems are missing or unproven. The weakest areas are Registration, Board Governance, Incident Resp. Unremediated gaps directly threaten patient safety (loss of access to EHR, imaging and medication systems), the continuity of clinical services (ransomware or outage with no tested recovery), and expose the organization to legal and regulatory liability under NIS2. This includes management accountability and potential penalties. Leadership should treat the items below as a time-bound program: address the 30-day actions immediately, fund the 60- and 90-day actions in this budget cycle, and review progress against the target maturity at the next board meeting.



Maturity Profile: Specialized Diagnostic Clinic



The solid blue area is the current maturity by domain; the green dashed line is the target profile (75%, Tier 3 'Defined/Compliant'). A regional hospital delivers essential healthcare services and is treated as an 'essential entity' under NIS2 (Annex I), so it is expected to reach the Defined/Compliant tier with controls fully documented, implemented and routinely tested, rather than merely Managed. Tier 4 (Optimized) is not required for compliance. Gaps between the blue area and the green line are the work still required in each domain.

Priority Remediation Plan

Each gap below the target maturity has a control-specific action with an accountable owner, due window, dependencies and the evidence required to close it.

RMM	Now	Target	Priority	Control-specific remediation
RMM001 Registration	0%	100%	Critical	Submit organization registration to the national CSIRT/NCSC portal and record the confirmation reference. Owner: Compliance Officer / DPO Due: 30 days Depends on: Confirmed entity classification (essential vs important) Evidence: NCSC registration confirmation ID
RMM002 Board Governance	0%	90%	Critical	Formalize board oversight: minute quarterly cyber reviews, approve an 18-month security budget, and complete mandatory board cyber training. Owner: Board / Executive Sponsor Due: 60 days Depends on: Board meeting calendar; annual budget cycle Evidence: Board minutes, approved budget line, training completion records
RMM014 Incident Resp	0%	90%	Critical	Finalize and approve the Incident Response Plan and run a tabletop exercise within 12 months. Owner: CISO / SOC Lead Due: 60 days Depends on: Detection capability (RMM015) Evidence: Approved IRP and tabletop exercise report

RMM	Now	Target	Priority	Control-specific remediation
RMM016 Continuity	0%	90%	Critical	Define a BCP with documented RTO/RPO for each critical system like EHR, PACS, LIS, medication systems, and network services. Test disaster recovery annually. Owner: IT Operations / Business Continuity Manager Due: 90 days Depends on: Critical-asset register (RMM004), DR environment Evidence: BCP with per-system RTO/RPO table and annual DR test report
RMM005 Measurement	6%	85%	Critical	Establish annual control testing/internal audit and a documented process to update measures after every incident. Owner: Internal Audit / CISO Due: 90 days Depends on: ISMS policy (RMM003) Evidence: Audit reports and post-incident review records
RMM012 Supply Chain	8%	85%	Critical	Risk-assess critical vendors and embed security SLAs and right-to-audit clauses in supplier contracts. Owner: Procurement / CISO Due: 90 days Depends on: Vendor list and legal review Evidence: Vendor risk assessments and updated contracts
RMM007 Asset Mgmt	12%	90%	Critical	Maintain an automated, up-to-date asset inventory with ownership and criticality tags. Owner: IT Operations Lead Due: 60 days Depends on: CMDB / network discovery tooling Evidence: Asset inventory export with last-updated timestamps
RMM013 Secure Dev	12%	85%	Critical	Build security requirements into system acquisition and run vulnerability management across new systems. Owner: IT Architecture / CISO Due: 90 days Depends on: Procurement process (RMM012) Evidence: Secure acquisition checklist and vulnerability scan reports
RMM004 Risk Assessment	16%	90%	Critical	Run a documented annual risk assessment and formally identify and classify critical clinical assets (EHR, PACS, LIS). Owner: CISO / Risk Manager Due: 60 days Depends on: Asset inventory (RMM007) Evidence: Risk register and critical-asset register
RMM015 Reporting	17%	100%	Critical	Operationalize 24h early-warning reporting: name a reporting owner, define the escalation path and weekend/out-of-hours cover, maintain a reporting template, and validate it with a test submission. Sustain IDS/SIEM detection coverage. Owner: SOC Lead / Compliance Officer Due: 30 days Depends on: SIEM, on-call rota, CSIRT contact details Evidence: Named owner + escalation runbook, reporting template, test-submission record
RMM003 Security Policy	17%	90%	Critical	Approve and publish an ISMS security policy set covering all NIS2 Art.21(2) risk areas; assign policy owners and annual review dates. Owner: CISO Due: 60 days Depends on: Risk assessment (RMM004) Evidence: Signed, version-controlled ISMS policy set
RMM009 Access Control	18%	100%	Critical	Enforce MFA on ALL remote and administrative access and apply least-privilege RBAC across systems. Owner: IT Security / IAM Lead Due: 30 days Depends on: Identity provider (e.g., Okta) rollout Evidence: MFA coverage report and privileged-access review
RMM006 Cyber Hygiene	38%	90%	Critical	Adopt risk-based patch SLAs: critical internet-facing vulnerabilities treated within 48-72h, high within 14 days, others within 30 days, with exceptions documented and formally approved. Test backup restorability annually and make cyber-hygiene training mandatory. Owner: IT Operations Lead Due: 30 days Depends on: Vulnerability scanning, patch automation, backup platform Evidence: Risk-based patch SLA policy, exception register, backup restore-test logs, training records
RMM011 Cryptography	40%	90%	Critical	Encrypt patient data at rest and enforce TLS in transit; manage keys through a central key-management service. Owner: CISO / IT Security Due: 60 days Depends on: Key management service Evidence: Encryption configuration evidence and TLS scan results

RMM	Now	Target	Priority	Control-specific remediation
RMM008 HR Security	46%	90%	High	Enforce background checks for sensitive roles and immediate access revocation on exit via a joiner-mover-leaver process. Owner: HR / IT Security Due: 60 days Depends on: HR system to IAM integration Evidence: Screening records and leaver deprovisioning logs

30-60-90 Day Remediation Roadmap

Sequenced view of the same actions so management can track progress towards target maturity after this assessment.

Window	RMM	Now	Target
Days 0-30 (Immediate)	RMM001 Registration	0%	100%
	RMM015 Reporting	17%	100%
	RMM009 Access Control	18%	100%
	RMM006 Cyber Hygiene	38%	90%
Days 31-60 (Short term)	RMM002 Board Governance	0%	90%
	RMM014 Incident Resp	0%	90%
	RMM007 Asset Mgmt	12%	90%
	RMM004 Risk Assessment	16%	90%
	RMM003 Security Policy	17%	90%
	RMM011 Cryptography	40%	90%
	RMM008 HR Security	46%	90%
Days 61-90 (Medium term)	RMM016 Continuity	0%	90%
	RMM005 Measurement	6%	85%
	RMM012 Supply Chain	8%	85%
	RMM013 Secure Dev	12%	85%

Business Continuity: Critical System Recovery Objectives

Recovery Time Objective (RTO) and Recovery Point Objective (RPO) targets for the hospital's critical systems (basis for RMM016). These objectives are validated by the disaster-recovery test schedule below.

Critical system	Criticality	RTO	RPO	Key dependency
Electronic Health Record (EHR)	Tier 1 - Critical	4 hours	15 minutes	Core network, identity
Medication management (ePMA / eMAR)	Tier 1 - Critical	2 hours	15 minutes	EHR, core network
Laboratory Information System (LIS)	Tier 1 - Critical	4 hours	30 minutes	EHR, core network
Picture Archiving & Communication (PACS)	Tier 2 - High	8 hours	1 hour	Storage, core network
Core network & identity (AD / DNS / DHCP)	Tier 1 - Critical	1 hour	15 minutes	Power, data center

Disaster-recovery test schedule

Frequency	Test	Owner
Quarterly	Backup restore test of one Tier 1 system (rotating schedule)	Infrastructure Lead
Semi-annually	Incident & DR tabletop exercise (clinical + IT participants)	CISO / SOC Lead
Annually	Full DR failover test with main-network isolation	IT Operations / BC Manager

Incident Reporting & 24-Hour Early-Warning Readiness (Art. 23)

Operational proof that the organization can submit a NIS2 'early warning' within 24 hours of becoming aware of a significant incident.

Element	Detail
Reporting owner	SOC Lead (primary); Duty IT Manager (deputy)
Escalation route	SOC analyst -> SOC Lead -> CISO -> Executive on-call -> national CSIRT / NCSC
Out-of-hours cover	24/7 on-call rota (ref OPS-ROTA-2026), 15-minute acknowledgement SLA
Reporting template	NCSC early-warning template TMPL-EW-01 (held in IRP-PROC-007 v1.0)
Statutory timeline	Early warning within 24h, incident notification within 72h, final report within 1 month
Test evidence	Simulated early-warning submission TEST-EW-2026-01, completed 2026-03-08

Appendix: Detailed Findings

ID	RMM	Article	Question	Resp.	Assur.	Evidence (document reference)	Pts
1	RMM001	Art.20(1)	Is there a designated officer for NIS2 compliance?	No	High	No designated NIS2 compliance officer; responsibility informally held by Practice Manager; no appointment record.	0.0
2	RMM002	Art.20(1)	Does the board explicitly approve cyber measures?	No	High	No board-level cyber oversight; directors rely on the IT managed-service provider (MSP); no cyber item in board minutes.	0.0
3	RMM002	Art.20(1)	Is there an approved cyber budget for 18 months?	No	Medium	No ring-fenced cyber budget; security spend bundled into the monthly MSP retainer (MSP-CON-2024).	0.0
4	RMM002	Art.20(2)	Do board members undergo mandatory cyber training?	No	High	No board or director cyber-governance training undertaken.	0.0
5	RMM003	Art.21(2)(a)	Is there a documented Security Policy (ISMS)?	Partial	Medium	Generic acceptable-use and IT policy supplied by MSP template (MSP-POL-001); not tailored or formally adopted.	1.5
6	RMM003	Art.21(2)	Does policy cover all NIS2 risk areas?	Partial	Low	MSP template covers acceptable use and basic access; supply chain, cryptography, continuity and measurement areas absent.	1.0
7	RMM004	Art.21(2)(a)	Are risk assessments conducted annually?	Partial	Low	MSP performs informal annual review; no documented ISO 27005-style risk assessment owned by the clinic.	1.5
8	RMM004	Art.21(2)(a)	Are critical assets (e.g., EHR) formally identified?	Partial	Medium	Key systems known informally (PACS/RIS, billing); no formal critical-asset register or classification.	1.0
9	RMM005	Art.21(2)(f)	Are measures audited/tested annually?	No	High	No independent control audit or effectiveness testing on record.	0.0
10	RMM005	Art.21(2)(a)	Is there a process to update measures post-incident?	Partial	Low	MSP applies fixes reactively after issues; no documented post-incident review owned by the clinic.	1.0
11	RMM006	Art.21(2)(e)	Is patching performed within defined SLAs?	Yes	Medium	MSP applies OS/security patching under managed-service SLA (MSP-SLA-2024, monthly cycle); clinic does not verify independently.	6.0
12	RMM006	Art.21(2)(c)	Are backups tested for restorability annually?	Partial	Low	MSP runs cloud backups; clinic has never witnessed or signed off a restore test.	1.5
13	RMM006	Art.21(2)(g)	Is cyber hygiene training mandatory for all staff?	Partial	Low	Ad-hoc phishing awareness emails; no mandatory enrolment or completion tracking.	1.0
14	RMM007	Art.21(2)(i)	Is the asset inventory up-to-date?	Partial	Low	MSP holds a partial device list; no clinic-maintained, reconciled inventory.	1.0
15	RMM008	Art.21(2)(i)	Are background checks performed for sensitive roles?	Yes	Medium	Pre-employment checks for clinical staff via HR; references and qualification checks retained.	4.0
16	RMM008	Art.21(2)(i)	Are access rights revoked immediately upon exit?	Partial	Low	Leaver access removal raised by email to MSP; no SLA, occasional delays observed.	1.0

ID	RMM	Article	Question	Resp.	Assur.	Evidence (document reference)	Pts
17	RMM009	Art.21(2)(j)	Is MFA enforced for ALL remote/admin access?	Partial	Medium	MFA enabled on Microsoft 365 email and VPN; not enforced on PACS/RIS admin or MSP remote-management tooling.	2.0
18	RMM009	Art.21(2)(j)	Is 'Least Privilege' strictly enforced?	Partial	Low	Some role separation between clinical and admin staff; shared and over-privileged accounts still common; no least-privilege review.	1.0
19	RMM010	Art.21(2)	Are physical server rooms secured?	Yes	Medium	Primary systems hosted in MSP/cloud data centre with physical security; on-site comms cabinet lockable.	4.0
20	RMM011	Art.21(2)(h)	Is patient data encrypted at rest?	Partial	Low	Cloud-hosted data encrypted by provider default; local imaging shares and some endpoints unencrypted.	1.5
21	RMM011	Art.21(2)(h)	Is data encrypted in transit (TLS)?	Yes	Medium	HTTPS/TLS for hosted applications and portal; SFTP for external image exchange.	4.0
22	RMM012	Art.21(2)(d)	Do supplier contracts include security SLAs?	Partial	Low	MSP master services agreement exists but lacks explicit security SLAs, breach-notification or right-to-audit clauses.	1.5
23	RMM012	Art.21(2)(d)	Are critical vendors risk-assessed?	No	Medium	MSP and software vendors not formally risk-assessed; no due-diligence questionnaires retained.	0.0
24	RMM013	Art.21(2)(e)	Is security built into system acquisition?	Partial	Low	Informal vendor selection considers data-handling at a basic level; no documented secure-acquisition gate.	1.0
25	RMM014	Art.21(2)(b)	Is there a documented Incident Response Plan?	No	High	No clinic-owned incident response plan; assumption that the MSP 'will handle it'.	0.0
26	RMM014	Art.21(2)(b)	Has the IRP been tested (tabletop) in 12 months?	No	High	No incident exercise or tabletop ever conducted.	0.0
27	RMM015	Art.23(3)	Can you submit an 'Early Warning' within 24h?	No	High	No capability or process to submit a 24h NIS2 early warning; no awareness of CSIRT contact route.	0.0
28	RMM015	Art.21(2)(b)	Are detection mechanisms (IDS/SIEM) in place?	Yes	Low	MSP provides basic endpoint protection and log monitoring; no clinic visibility of alerts or coverage.	4.0
29	RMM016	Art.21(2)(c)	Is there a Business Continuity Plan with RTOs?	No	High	No business continuity plan with RTO/RPO; downtime procedures undocumented.	0.0
30	RMM016	Art.21(2)(c)	Are DR procedures tested annually?	No	High	No disaster-recovery test performed or evidenced.	0.0